

Risk: If production is deployed with NODE_ENV=development, rate limits and CAPTCHA defaults are weaker, increasing brute-force and abuse risk.

Recommendation: Add startup checks for production deployments and fail closed unless NODE_ENV, HTTPS cookies, Turnstile, strong secrets, and proxy settings are correct.

Medium Risk

Refresh token rotation has a concurrency race

Severity: Medium

Evidence: backend/src/controllers/authController.ts:302-339;
backend/src/services/refreshSessionService.ts:68-99

Risk: Two simultaneous refresh requests can both validate before revocation, reducing replay-detection strength.

Recommendation: Rotate tokens with an atomic conditional update inside one transaction and require exactly one affected row before creating the next session.

OG image endpoint can leak unpublished article metadata

Severity: Medium

Evidence: backend/src/controllers/ogController.ts:145-159

Risk: A known draft/submitted slug can reveal title, author, and category through /og/article/:slug.

Recommendation: Require status=PUBLISHED for public OG image generation unless caller is authenticated as owner/admin.

Public series endpoint can expose draft article metadata

Severity: Medium

Evidence: backend/src/controllers/articleController.ts:822-843

Risk: Series responses include member article status, title, slug, excerpt, and image even if articles are not published.

Recommendation: Filter public series members to published articles. Show unpublished members only to owner/admin.

Poll endpoints can expose unpublished article polls

Severity: Medium

Evidence: backend/src/controllers/pollController.ts:89-124 and 220-255

Risk: Polls linked to unpublished content may be retrievable by ID or article ID.

Recommendation: When a poll has articleId, verify linked article visibility before returning poll data.